

CISM CERTIFICATION EXAM SIMULATOR

# Practice Exam 32

## Domain IV - Incident Management

|                 |               |                              |
|-----------------|---------------|------------------------------|
| 43<br>Questions | 69<br>Minutes | Single Best<br>Answer Format |
|-----------------|---------------|------------------------------|

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

# Instructions

- Allow approximately 69 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

## Questions

### Question 1 (CISM8-108)

*Scenario: An inland aquaculture operator sees unauthorized feeding cycles scheduled during a night shift. The single executive authorized to suspend automation is abroad and unavailable.*

**Which delegated decision model would BEST support timely and controlled suspension?**

- A. Document risk-based suspension authority, limits, alternates, and escalation paths.
- B. Require feeding operations to continue until the vice president returns.
- C. Allow every employee to disable all aquaculture systems permanently.
- D. Transfer all feeding-system risk decisions to the equipment supplier.

### Question 2 (CISM8-109)

**Which change MOST clearly justifies an immediate response-plan update?**

- A. An acquisition changes regulated services, reporting lines, suppliers, and escalation contacts.
- B. A dashboard receives a new color palette.
- C. A team changes its weekly meeting agenda.
- D. A low-impact office utility receives a routine update.

### Question 3 (CISM8-110)

*Scenario: A medical school and research institute share a clinical-data environment, but both organizations believe their own manager has final isolation authority.*

**Which shared-governance mechanism should be defined before the platform expands?**

- A. Separate command structures that exchange information only after closure.
- B. Automatic public disclosure by either company without coordination.
- C. A rule that the first analyst to see an alert controls both companies.
- D. A joint response model defining accountable ownership, isolation authority, information flow, and escalation.

**Question 4 (CISM8-111)**

*Scenario: A nationwide wholesaler has replaced internal infrastructure teams with several service providers, but its plan still names departed employees and old communication paths.*

**What plan revision would BEST align response with the current sourcing model?**

- A. Add more malware indicators to the cyber plan.
- B. Let each plan owner retain incompatible terminology.
- C. Create common governance, activation interfaces, decision authority, and tested handoffs across the plans.
- D. Assign internal audit to lead every operational response.

**Question 5 (CISM8-112)**

*Scenario: A passenger-rail company marks its operations-data repository as critical while excluding directory, time, route-feed, and network dependencies.*

**What is the GREATEST risk of omitting these supporting services?**

- A. The incident log may contain too many entries.
- B. The repository hardware may be overinsured.
- C. Recovery sequencing may fail because required supporting services are absent.
- D. Every repository alert will necessarily become a disaster.

**Question 6 (CISM8-113)**

*Scenario: A major venue uses a digital-entry credential service that is low priority most weeks but essential during a narrow event-admission window.*

**Which readiness approach BEST reflects the credential service's changing criticality?**

- A. Use only average annual transaction volume.
- B. Use time-sensitive priority, staffing, escalation, and recovery requirements for the peak period.
- C. Rate every credential event at maximum severity all year.
- D. Set priority from the number of servers alone.

**Question 7 (CISM8-114)**

*Scenario: A consumer-finance company has an approved restoration time for applications but no approved tolerance for losing recent submissions.*

**Which missing objective addresses acceptable transaction loss?**

- A. A recovery point objective based on acceptable loss of loan-application transactions.
- B. A target number of security alerts per day.
- C. A maximum duration for responder interviews.
- D. A standard attendance level for tabletop exercises.

**Question 8 (CISM8-115)**

**What should coordinated continuity planning enable during an incident?**

- A. To sustain prioritized activity while containment, recovery, and restoration proceed.
- B. To activate alternate sites for every security event.
- C. To replace containment with manual processing.
- D. To transfer investigation ownership to business staff.

**Question 9 (CISM8-116)**

*Scenario: The designated alternate-work channel depends on an endpoint-management platform that responders expect to quarantine during the modeled incident.*

**How should the organization remove the shared dependency from its workaround?**

- A. Accept the design because the workspace is externally hosted.
- B. Develop and test an alternate access method that does not depend on the affected mobile-device management service.
- C. Increase identity log retention without changing access.
- D. Delay all continuity activity until the identity service returns.

**Question 10 (CISM8-117)**

*Scenario: A pharmacy network tests its paper process and finds it can handle only 18 percent of demand against an approved 50 percent target.*

**Which management decision BEST addresses the tested capacity deficit?**

- A. Approve the process because some results can be recorded.
- B. Lower the minimum without clinical-owner approval.
- C. Wait for an outage to learn whether the shortfall matters.
- D. Redesign and exercise the process to meet the approved requirement or formally address the gap.

**Question 11 (CISM8-118)**

*Scenario: A trade association's recovery plan starts member applications before recovering the directory and certificate services required for sign-in.*

**How should these components be ordered for recovery?**

- A. Restore the directory and certificate services before applications that depend on it.
- B. Give all components the same recovery point objective.
- C. Recover the most visible application first regardless of prerequisites.
- D. Let each application team choose independently.

**Question 12 (CISM8-119)**

*Scenario: During a recovery exercise, infrastructure starts successfully but users cannot authenticate and business transactions are never validated.*

**Which validation step is necessary before accepting the recovery result?**

- A. Only host startup times.
- B. End-to-end validation of access, data, interfaces, transactions, dependencies, and recovery objectives.
- C. A review of office furniture at the alternate site.
- D. A larger inventory of backup media.

**Question 13 (CISM8-120)**

**Which statement correctly explains the two recovery objectives?**

- A. Both terms describe the maximum length of an investigation.
- B. RTO measures lost data, while RPO measures staff availability.
- C. RTO addresses acceptable restoration time, while RPO addresses acceptable data loss measured in time.
- D. Both terms are always identical to supplier service levels.

**Question 14 (CISM8-121)**

*Scenario: A game publisher uses affected-device count for severity, so compromise of one release-signing key ranks below adware found on public demonstration kiosks.*

**Which severity criteria would BEST recognize the signing-key impact?**

- A. Base severity only on hardware replacement cost.
- B. Assign maximum severity to every signing-key alert.
- C. Let each responder choose a rating without criteria.
- D. Include information sensitivity, software-trust impact, trust, scope, urgency, and applicable obligations.

**Question 15 (CISM8-122)**

*Scenario: A hotel operator relies on personal judgment to escalate incidents, leading to inconsistent involvement of legal, safety, franchise, and senior leadership.*

**How should the organization make escalation consistent and repeatable?**

- A. Documented thresholds based on impact, data, scope, urgency, safety, and obligations.
- B. Escalation whenever any user requests it.
- C. Escalation only after financial loss is final.
- D. Board escalation for every blocked alert.

**Question 16 (CISM8-123)**

*Scenario: A content platform assigns outages, account abuse, unauthorized edits, and privacy events to one undifferentiated urgent queue.*

**Which classification change would BEST route these incidents?**

- A. Retain one label and add more email recipients.
- B. Create one severity for every content title.
- C. Use estimated repair hours as the sole field.
- D. Separate category and severity, then map their combinations to owners, actions, authority, and escalation.

**Question 17 (CISM8-124)**

*Scenario: A utility exercise confirms technical strength but exposes missing alternates for command, regulatory coordination, and leadership briefings.*

**Which action BEST closes the cross-functional competency gaps?**

- A. Teach board members to analyze malware.
- B. Map competencies to roles, assign trained personnel and alternates, and retest the gaps.
- C. Ask a contractor to make all corporate decisions.
- D. Remove customs and board injects from later tests.

**Question 18 (CISM8-125)**

*Scenario: A credit provider repeats a well-known tabletop script, allowing participants to anticipate each development and recite approved responses.*

**What change would make future exercises more diagnostic?**

- A. Stop documenting results because performance is consistent.
- B. Score only the speed of alert recognition.
- C. Use varied scenarios and injects tied to decision, coordination, communication, and recovery objectives.
- D. Exclude business leaders to shorten the session.

**Question 19 (CISM8-126)**

**Which exercise method BEST tests leadership without production impact?**

- A. An unannounced shutdown of live systems.
- B. A routine vulnerability scan.
- C. A count of employees who downloaded the plan.
- D. A facilitated tabletop with progressive business and stakeholder injects.

**Question 20 (CISM8-127)**

*Scenario: A simulation documents slow partner escalation but ends without accountable actions, completion evidence, or planned retesting.*

**What should be added to the exercise closeout process?**

- A. Use attendance as the only success measure.
- B. Delete difficult observations before leadership review.
- C. Create prioritized corrective actions with owners, dates, validation evidence, and retesting.
- D. Approve the plan because the simulation ended.

**Question 21 (CISM8-128)**

**Which initial decision belongs to incident triage?**

- A. An initial determination of incident status, impact, priority, ownership, and routing.
- B. A completed root-cause analysis.
- C. A final external notification package.
- D. A permanent redesign of affected systems.

**Question 22 (CISM8-129)**

*Scenario: A property operator sees routine blocked scans while fire-control settings change without authorization in an occupied building.*

**Which condition warrants the FIRST investigation priority?**

- A. The fire-suppression changes because possible integrity and patient-safety impact require urgent triage.
- B. Both after the next scheduled meeting.
- C. Neither until malicious intent is proven.
- D. The scans because they contain more events.

**Question 23 (CISM8-130)**

*Scenario: Volunteers maintaining a public-assistance portal report suspicious activity through informal messages that are not monitored continuously.*

**Which reporting-channel design would BEST address the missed messages?**

- A. Require volunteers to prove compromise before reporting.
- B. Ask coordinators to conduct forensic analysis.
- C. Provide a monitored supplier-reporting channel with acknowledgment, intake guidance, and escalation.
- D. Ignore reports from volunteers below a participation threshold.

**Question 24 (CISM8-131)**

*Scenario: A robotic fulfillment cell begins entering a pedestrian zone; activating the safety stop may erase temporary controller data.*

**What should the incident manager authorize FIRST?**

- A. Continue unsafe production until all data is collected.
- B. Place the process in a safe state using authorized procedures, document actions, and preserve feasible evidence.
- C. Erase the controller without recording the action.
- D. Wait for the equipment vendor to decide whether safety matters.

**Question 25 (CISM8-132)**

*Scenario: A database specialist whose privileged queries are in scope is asked to lead evidence collection because colleagues lack equivalent system knowledge.*

**Which approach BEST preserves investigative independence?**

- A. Assign independent investigators, control access as authorized, and coordinate with legal and human resources.
- B. Accept a verbal summary from the administrator.
- C. Stop the inquiry unless the administrator agrees.
- D. Publicly name the administrator before validation.

**Question 26 (CISM8-133)**

*Scenario: Access-control records tied to missing inventory are copied repeatedly without logging the source, integrity values, handlers, or transfers.*

**Why is the current evidence handling inadequate?**

- A. Evidence integrity and provenance may be challenged because custody was not maintained.
- B. The records necessarily identify the wrong employee.
- C. The incident automatically becomes a disaster.
- D. Every recovery objective must be shortened.

**Question 27 (CISM8-134)**

*Scenario: A multinational business wants to collect complete support-call recordings across jurisdictions after suspected insider activity, but applicable local restrictions vary.*

**Which specialist coordination is required before broad collection?**

- A. Collect every recording immediately under one global rule.
- B. Let local supervisors decide legal authority individually.
- C. Coordinate legal, privacy, human resources, and investigators on lawful, proportionate collection and preservation.
- D. Notify the suspected individuals publicly.

**Question 28 (CISM8-135)**

**Which set of factors should govern the containment choice?**

- A. The personal preference of the first analyst.
- B. The length of the technical procedure.
- C. The action used in the previous incident.
- D. The balance among continuing harm, safety, business impact, evidence, authority, and recovery options.

**Question 29 (CISM8-136)**

*Scenario: One reseller credential is actively abusing a benefits platform while other resellers are completing deadline-driven transactions.*

**Which action provides the BEST targeted containment?**

- A. Leave the key active until service delivery closes.
- B. Revoke the affected key, isolate the reseller connection, preserve records, and monitor for related abuse.
- C. Disable the entire platform without assessing narrower options.
- D. Delete API logs before isolation.

**Question 30 (CISM8-137)**

*Scenario: An airport must retain unpatchable information displays temporarily; segmented administration controls exposure but requires extra operational effort.*

**How should management approve and control the temporary restriction?**

- A. Restore unrestricted connectivity to improve speed.
- B. Accept the exposure indefinitely without approval.
- C. Implement tested, monitored, business-approved restrictions with an expiration date and tracked replacement.
- D. Disconnect every display without considering airport operations.

**Question 31 (CISM8-138)**

*Scenario: A widely shared post alleges that a relief organization published recipient identities, while the response team has confirmed only service unavailability.*

**Which public update is MOST appropriate at this stage?**

- A. Issue an approved holding statement describing verified impact, response activity, and update channels.
- B. Publish investigators' competing theories.
- C. Remain silent until every corrective action is complete.
- D. Confirm the rumored loss to appear decisive.

**Question 32 (CISM8-139)**

*Scenario: A hosted-services company finds possible exposure across customers governed by different contracts, regulators, insurance clauses, and locations.*

**Which notification activity should start while scope is still developing?**

- A. One universal deadline copied from an unrelated rule.
- B. A coordinated legal, privacy, contract, insurance, and business assessment of verified facts and applicable duties.
- C. A statement that every customer suffered identity theft.
- D. A delay until final root-cause analysis.

**Question 33 (CISM8-140)**

*Scenario: During unauthorized cloud changes, leaders receive raw technical events and engineers receive only a possible reputation estimate.*

**Which status-reporting model would BEST meet both audiences' needs?**

- A. Send identical raw detail to every recipient.
- B. Stop scheduled updates and answer only questions.
- C. Allow teams to publish independent estimates.
- D. Create audience-specific updates from one verified incident record, aligned with decision needs and cadence.

**Question 34 (CISM8-141)**

*Scenario: A cyber disruption halts emergency medication distribution across a region during flooding, but the incident remains under routine technical coordination.*

**Which crisis-management step is MOST appropriate now?**

- A. Wait for final technical root cause.
- B. Activate crisis coordination for operational, executive, government, partner, and public communication needs.
- C. Allow individual analysts to brief the public.
- D. Close the incident because pharmacy operators own service delivery.

**Question 35 (CISM8-142)**

*Scenario: A restored cloud application appears clean, but unauthorized refresh tokens and a compromised recovery identity still permit access.*

**Which remaining eradication work must precede restoration?**

- A. Declare eradication complete because the known malicious component is gone.
- B. Restore access and address sessions later.
- C. Revoke unauthorized sessions, secure recovery paths, remediate the weakness, and validate removal of persistence.
- D. Close the incident and treat the recovery-account issue as routine support.

**Question 36 (CISM8-143)**

**What does recovery validation establish before normal reliance?**

- A. To transfer acceptance authority to a vendor.
- B. To prove no future incident can occur.
- C. To remove the need for enhanced monitoring.
- D. To confirm functionality, integrity, security, dependencies, and agreed business outcomes before normal use.

**Question 37 (CISM8-144)**

*Scenario: An inventory system is online after tampering, but system quantities conflict with signed physical counts.*

**Which condition must be met before resuming normal inventory transactions?**

- A. Resume inventory processing because infrastructure tests pass.
- B. Maintain restrictions until reconciliation and recovery criteria are satisfied and the designated business owner accepts service.
- C. Let the hosting supplier accept the discrepancy.
- D. Declare success solely because the RTO was reached.

**Question 38 (CISM8-145)**

*Scenario: A commerce service passes restoration tests after credential misuse, though the team needs additional assurance during stabilization.*

**How should monitoring change during the early restored-service period?**

- A. Disable logging to improve performance.
- B. Immediately delete all incident indicators.
- C. Keep the service offline until all enterprise risk disappears.
- D. Restore service gradually with enhanced recurrence monitoring

**Question 39 (CISM8-146)**

*Scenario: A service assistant exposed internal guidance after manipulated image input, while existing risk scenarios and response criteria address text only.*

**Which improvement plan BEST incorporates the image-input lessons?**

- A. Document the event but retain existing assumptions.
- B. Rely only on employee reminders.
- C. Reassess the risk, revise response criteria and safeguards, train relevant roles, and test image-input scenarios.
- D. Permanently ban all multimodal service without business analysis.

**Question 40 (CISM8-147)**

*Scenario: After restricted records are published accidentally, leadership proposes a review focused entirely on the person who approved the workflow.*

**How should the review balance learning and individual accountability?**

- A. Exclude process owners.
- B. Examine design, approvals, workload, training, oversight, and contributing factors while using proper personnel channels.
- C. Cancel the review because human error was involved.
- D. Begin by publicly naming the employee.

**Question 41 (CISM8-148)**

*Scenario: Backup jobs continue failing because ownership is absent, alerts reach a disabled account, and missed runs have no escalation path.*

**Which finding represents the underlying management-process failure?**

- A. Business users did not receive recent backup confirmations.
- B. Backup-job governance failed to assign ownership, monitor failures, and escalate missed action.
- C. Responders restarted several backup agents.
- D. The service desk received questions about restore readiness.

**Question 42 (CISM8-149)**

*Scenario: Improvement actions from a partner-access incident remain in minutes without assigned owners, dates, evidence, or approved exceptions.*

**Which process would BEST ensure the actions reach verified closure?**

- A. Verbal completion claims without evidence.
- B. Automatic closure after a fixed number of months.
- C. A governed corrective-action register with ownership, priority, dates, validation, escalation, and formal risk acceptance.
- D. Progress review limited to original responders.

**Question 43 (CISM8-150)**

*Scenario: A passenger-transport firm reports incident volume but cannot show trends in harm, response duration, recurrence, recovery, or remediation.*

**Which metrics would BEST support management evaluation of improvement?**

- A. Only alerts generated per tool.
- B. Only responder labor hours.
- C. Only incidents marked closed.
- D. Impact, response, recurrence, recovery, and remediation trends

# Answer Key

## Domain IV - Incident Management

|      |      |      |      |      |
|------|------|------|------|------|
| 1 A  | 2 A  | 3 D  | 4 C  | 5 C  |
| 6 B  | 7 A  | 8 A  | 9 B  | 10 D |
| 11 A | 12 B | 13 C | 14 D | 15 A |
| 16 D | 17 B | 18 C | 19 D | 20 C |
| 21 A | 22 A | 23 C | 24 B | 25 C |
| 26 A | 27 C | 28 D | 29 B | 30 C |
| 31 A | 32 B | 33 D | 34 B | 35 C |
| 36 D | 37 B | 38 D | 39 C | 40 B |
| 41 B | 42 A | 43 D |      |      |

# Detailed Explanations

## Question 1 (CISM8-108)

**Correct answer: A - Document risk-based suspension authority, limits, alternates, and escalation paths.**

For this case, bounded delegation enables timely containment while preserving accountability. Waiting permits potential harm, unrestricted authority is excessive, and a vendor cannot assume the cooperative's final risk decision.

## Question 2 (CISM8-109)

**Correct answer: A - An acquisition changes regulated services, reporting lines, suppliers, and escalation contacts.**

For this case, an acquisition can invalidate scope, ownership, dependencies, contacts, and obligations. Meeting formats, presentation colors, and routine low-impact updates do not materially alter response governance.

## Question 3 (CISM8-110)

**Correct answer: D - A joint response model defining accountable ownership, isolation authority, information flow, and escalation.**

For this case, a joint model resolves authority and coordination before an incident occurs. Separate command delays decisions, initial detection does not confer enterprise authority, and uncoordinated disclosure can conflict with verified facts and obligations.

## Question 4 (CISM8-111)

**Correct answer: C - Create common governance, activation interfaces, decision authority, and tested handoffs across the plans.**

For this case, common governance and tested interfaces prevent conflicting activation and ownership. More indicators do not resolve coordination, incompatible terms preserve ambiguity, and internal audit should not assume operational command.

## Question 5 (CISM8-112)

**Correct answer: C - Recovery sequencing may fail because required supporting services are absent.**

For this case, a critical service cannot be restored effectively without its prerequisites. Log volume and insurance are unrelated, and missing dependencies do not automatically make every alert a disaster.

## Question 6 (CISM8-113)

**Correct answer: B - Use time-sensitive priority, staffing, escalation, and recovery requirements for the peak period.**

For this case, time-sensitive requirements reflect the period of greatest business harm. Annual averages conceal peak exposure, permanent maximum severity wastes resources, and server count is not a business-impact measure.

**Question 7 (CISM8-114)**

**Correct answer: A - A recovery point objective based on acceptable loss of loan-application transactions.**

For this case, the RPO defines acceptable data loss and complements the time objective. Alert volume, interview duration, and exercise attendance do not establish the permissible rollback of loan-application data.

**Question 8 (CISM8-115)**

**Correct answer: A - To sustain prioritized activity while containment, recovery, and restoration proceed.**

For this case, continuity sustains essential business activity during disruption while incident teams address the cause and recovery. It does not own investigations, activate for every event, or replace containment decisions.

**Question 9 (CISM8-116)**

**Correct answer: B - Develop and test an alternate access method that does not depend on the affected mobile-device management service.**

For this case, an effective workaround must avoid the likely failed dependency and be tested. External hosting does not remove device-management reliance, more logs do not restore access, and delay defeats continuity objectives.

**Question 10 (CISM8-117)**

**Correct answer: D - Redesign and exercise the process to meet the approved requirement or formally address the gap.**

For this case, the known gap should be corrected and tested or explicitly accepted by accountable owners. Partial capacity, an unauthorized requirement change, or waiting for a real incident leaves patient-service risk unmanaged.

**Question 11 (CISM8-118)**

**Correct answer: A - Restore the directory and certificate services before applications that depend on it.**

For this case, the identity foundation is a prerequisite and must be restored before dependent applications can operate securely. Equal RPOs do not solve order, visibility does not override dependency, and independent sequencing creates conflicts.

**Question 12 (CISM8-119)**

**Correct answer: B - End-to-end validation of access, data, interfaces, transactions, dependencies, and recovery objectives.**

For this case, server startup does not prove business usability. End-to-end testing validates the complete recovered service, while host timing, media inventory, and furniture do not demonstrate operational recovery.

**Question 13 (CISM8-120)**

**Correct answer: C - RTO addresses acceptable restoration time, while RPO addresses acceptable data loss measured in time.**

For this case, rTO concerns how quickly service must return; RPO concerns how much data loss is acceptable. Neither measures staffing or investigation duration, and supplier targets need not equal business objectives.

**Question 14 (CISM8-121)**

**Correct answer: D - Include information sensitivity, software-trust impact, trust, scope, urgency, and applicable obligations.**

For this case, multidimensional criteria capture the potential software-trust impact of one critical signing key. Hardware cost and unstructured judgment are inadequate, while automatic maximum ratings ignore verified context.

**Question 15 (CISM8-122)**

**Correct answer: A - Documented thresholds based on impact, data, scope, urgency, safety, and obligations.**

For this case, objective thresholds enable consistent, timely routing to appropriate stakeholders. Final loss is too late, user requests alone are insufficient, and board involvement for every alert creates noise.

**Question 16 (CISM8-123)**

**Correct answer: D - Separate category and severity, then map their combinations to owners, actions, authority, and escalation.**

For this case, category identifies incident nature and severity expresses impact and urgency; mapping both improves routing. Title-level severities are unwieldy, repair time is incomplete, and wider email distribution does not resolve ambiguity.

**Question 17 (CISM8-124)**

**Correct answer: B - Map competencies to roles, assign trained personnel and alternates, and retest the gaps.**

For this case, role mapping, training, alternates, and retesting address the actual readiness weaknesses. Technical board training, narrower exercises, and outsourced corporate authority do not.

**Question 18 (CISM8-125)**

**Correct answer: C - Use varied scenarios and injects tied to decision, coordination, communication, and recovery objectives.**

For this case, varied objective-driven exercises test judgment rather than memory. Removing documentation, relying on one technical metric, or excluding leaders weakens assurance over management response.

**Question 19 (CISM8-126)**

**Correct answer: D - A facilitated tabletop with progressive business and stakeholder injects.**

For this case, a facilitated tabletop safely tests leadership decisions and cross-functional coordination. A live shutdown creates risk, a scan tests controls, and download counts do not demonstrate capability.

**Question 20 (CISM8-127)**

**Correct answer: C - Create prioritized corrective actions with owners, dates, validation evidence, and retesting.**

For this case, accountable actions and retesting turn findings into measurable improvement. Suppression, attendance alone, and exercise completion do not show that identified gaps are resolved.

**Question 21 (CISM8-128)**

**Correct answer: A - An initial determination of incident status, impact, priority, ownership, and routing.**

For this case, triage establishes whether reported activity is an incident and how it should initially be handled. Root cause, notification, and redesign require later facts and authorization.

**Question 22 (CISM8-129)**

**Correct answer: A - The fire-suppression changes because possible integrity and patient-safety impact require urgent triage.**

For this case, potentially altered fire-suppression settings create immediate occupant-safety risk and outweigh blocked scans. Event volume alone is not impact, and waiting for a meeting or proven intent may allow harm.

**Question 23 (CISM8-130)**

**Correct answer: C - Provide a monitored supplier-reporting channel with acknowledgment, intake guidance, and escalation.**

For this case, a monitored channel supports early, consistent reporting and triage. Proof requirements and coordinator investigations delay response, while volunteer role does not determine incident relevance.

**Question 24 (CISM8-131)**

**Correct answer: B - Place the process in a safe state using authorized procedures, document actions, and preserve feasible evidence.**

For this case, safety and stabilization take priority, while documentation and feasible evidence collection should continue. Continuing unsafe operation is unacceptable, undocumented erasure harms investigation, and the organization retains safety authority.

**Question 25 (CISM8-132)**

**Correct answer: C - Stop the inquiry unless the administrator agrees.**

For this case, independent oversight protects evidence and due process while appropriate specialists coordinate personnel and legal issues. Self-investigation creates conflict, consent is not the governing condition, and public attribution is premature.

**Question 26 (CISM8-133)**

**Correct answer: A - Evidence integrity and provenance may be challenged because custody was not maintained.**

For this case, missing integrity and handling records weaken evidentiary reliability. They do not predetermine attribution, define a disaster, or justify unrelated recovery changes.

**Question 27 (CISM8-134)**

**Correct answer: C - Coordinate legal, privacy, human resources, and investigators on lawful, proportionate collection and preservation.**

For this case, cross-border collection requires specialist coordination to establish authority, proportionality, handling, and preservation. A universal rule may be unlawful, supervisors are not legal decision makers, and public identification is premature.

**Question 28 (CISM8-135)**

**Correct answer: D - The balance among continuing harm, safety, business impact, evidence, authority, and recovery options.**

For this case, containment is a risk-based decision balancing harm reduction with operational, evidentiary, safety, authority, and recovery needs. Preference, precedent, and document length alone are insufficient.

**Question 29 (CISM8-136)**

**Correct answer: B - Revoke the affected key, isolate the reseller connection, preserve records, and monitor for related abuse.**

For this case, targeted revocation stops the confirmed path while limiting business impact and preserving evidence. Delay permits harm, full shutdown may be disproportionate, and log deletion impairs investigation.

**Question 30 (CISM8-137)**

**Correct answer: C - Implement tested, monitored, business-approved restrictions with an expiration date and tracked replacement.**

For this case, time-bounded compensating measures balance reduced exposure with operations until remediation. Convenience does not justify risk, indefinite acceptance lacks accountability, and wholesale disconnection may create safety issues.

**Question 31 (CISM8-138)**

**Correct answer: A - Issue an approved holding statement describing verified impact, response activity, and update channels.**

For this case, a factual holding statement addresses stakeholder needs without spreading unsupported claims. Confirming rumors or theories is premature, while prolonged silence can worsen confusion.

**Question 32 (CISM8-139)**

**Correct answer: B - A coordinated legal, privacy, contract, insurance, and business assessment of verified facts and applicable duties.**

For this case, notification assessment should start promptly using verified facts and applicable obligations. A universal deadline may be wrong, asserted harm may be unsupported, and full root cause is not required to begin analysis.

**Question 33 (CISM8-140)**

**Correct answer: D - Create audience-specific updates from one verified incident record, aligned with decision needs and cadence.**

For this case, a common verified source maintains consistency while tailored reporting supports each role. Uniform detail creates noise, independent estimates conflict, and purely reactive communication weakens oversight.

**Question 34 (CISM8-141)**

**Correct answer: B - Activate crisis coordination for operational, executive, government, partner, and public communication needs.**

For this case, widespread essential-service impact requires enterprise crisis coordination while technical response continues. Waiting delays action, individual briefings create inconsistency, and operational ownership does not end the incident.

**Question 35 (CISM8-142)**

**Correct answer: C - Revoke unauthorized sessions, secure recovery paths, remediate the weakness, and validate removal of persistence.**

For this case, eradication must address all known access paths and enabling weaknesses. Removing one artifact is incomplete, delay preserves unauthorized access, and routine-ticket treatment would close the incident prematurely.

**Question 36 (CISM8-143)**

**Correct answer: D - To confirm functionality, integrity, security, dependencies, and agreed business outcomes before normal use.**

For this case, validation establishes that the service is trustworthy and fit for business use. It cannot prove zero future risk, replace monitoring, or transfer organizational acceptance.

**Question 37 (CISM8-144)**

**Correct answer: B - Maintain restrictions until reconciliation and recovery criteria are satisfied and the designated business owner accepts service.**

For this case, availability alone does not prove integrity. Restrictions should remain until validation and business acceptance; suppliers cannot accept organizational risk, and reaching the RTO does not override failed reconciliation.

**Question 38 (CISM8-145)**

**Correct answer: D - Restore service gradually with enhanced recurrence monitoring**

For this case, controlled return with enhanced monitoring provides assurance during stabilization. Disabling visibility or deleting indicators is premature, while waiting for elimination of all risk is impractical.

**Question 39 (CISM8-146)**

**Correct answer: C - Reassess the risk, revise response criteria and safeguards, train relevant roles, and test image-input scenarios.**

For this case, the review should update risk assumptions, safeguards, procedures, training, and exercises based on observed behavior. No change or reminders alone are incomplete, while a blanket ban may be disproportionate.

**Question 40 (CISM8-147)**

**Correct answer: B - Examine design, approvals, workload, training, oversight, and contributing factors while using proper personnel channels.**

For this case, a systemic review identifies sustainable improvements and supports candor. Excluding owners, public blame, or cancellation leaves organizational weaknesses unresolved.

**Question 41 (CISM8-148)**

**Correct answer: B - Backup-job governance failed to assign ownership, monitor failures, and escalate missed action.**

For this case, the failed ownership, monitoring, and escalation process explains the recurring backup failures. Missing confirmations and questions are symptoms, while restarting agents is a response action rather than the systemic root cause.

**Question 42 (CISM8-149)**

**Correct answer: A - Verbal completion claims without evidence.**

For this case, a governed register turns lessons into accountable and verifiable improvement and exposes residual-risk decisions. Time, unsupported claims, and narrow review do not demonstrate completion.

**Question 43 (CISM8-150)**

**Correct answer: D - Impact, response, recurrence, recovery, and remediation trends**

For this case, balanced measures connect operations to business consequence, timeliness, repeated causes, recovery, and improvement. Alert, labor, or closure counts alone can hide deteriorating risk.